

V0088

Advanced Information Security

高级信息安全

Instructor: **Prof. Xiaohong Yu**

Graduate School of Information and Communication Technology,
Ajou University, Korea

访问控制

- 身份验证 (Authentication)
 - ...
- 授权 (Authorization)
 - 基础访问控制 (简介, 访问控制矩阵)
 - 经典安全模型 (多级安全模型, 多边安全)
 - 进阶安全 (隐蔽通道, 推理控制)
 - 应用 (CHAPTCHA, 防火墙, 入侵检测)

简介

- 授权：访问控制中涉及到限制认证用户的行为的部分。
 - 对已认证用户的操作限制。

项目	身份验证 (Authentication)	授权 (Authorization)
作用	确认“你是谁”	决定“你能做什么”
发生顺序	先发生	后发生
依据	用户凭证 (密码、指纹等)	权限规则
结果	是否允许登录	是否允许访问资源

简介

- 授权：访问控制中涉及到限制认证用户的行为的部分。
 - 对已认证用户的操作限制。

R = Read (读取)

W = Write (写入)

E = Execute (执行/使用)

M = Modify (修改/管理)

主体 \ 客体	成绩系统	课程资料	作业系统	学校系统
教师 (Teacher)	R, W, M	R, W	R, W	R
助教 (TA)	R, W	R	R, W	—
学生 (Student)	R	R	R, W	—

访问控制矩阵

- 主体：系统的用户，用S表示 (Subject)
- 客体：系统的资源，用O表示 (Object)

主体 \ 客体	成绩系统	课程资料	作业系统	学校系统
教师 (Teacher)	R, W, M	R, W	R, W	R
助教 (TA)	R, W	R	R, W	—
学生 (Student)	R	R	R, W	—

访问控制矩阵

- **访问控制矩阵**包含**所有**相关信息
- 可能有数百名用户， 数万份资源。
 - 那么， 该矩阵就有数百万个元素。
- 如何管理如此庞大的矩阵？
- 任何用户访问任何资源之前， 我们需要检查此矩阵。
- 如何提高效率/实用性？

访问控制矩阵

- 在授权领域中，有两个基本概念：
 - 访问控制列表(ACL)
 - 能力表(C-list)
- ACL和C-list都是从Lampson访问控制矩阵中衍生而来的。

	操作系统	会计程序	会计数据	保险数据	薪水数据
Bob	rx	rx	r	—	—
Alice	rx	rx	r	rw	rw
Sam	rwX	rwX	r	rw	rw
会计程序	rx	rx	rw	rw	r

访问控制列表 (ACL)

- ACL: 按列存储访问控制矩阵
- 示例: 保险数据的 ACL 以蓝色框显示。

(Bob, —), (Alice, rw), (Sam, rw), (会计程序, rw)

	操作系统	会计程序	会计数据	保险数据	薪水数据
Bob	rx	rx	r	—	—
Alice	rx	rx	r	rw	rw
Sam	rwX	rwX	r	rw	rw
会计程序	rx	rx	rw	rw	r

能力表 (C-list)

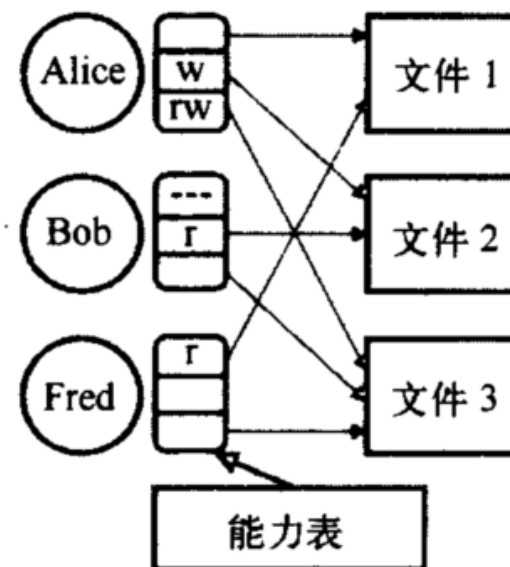
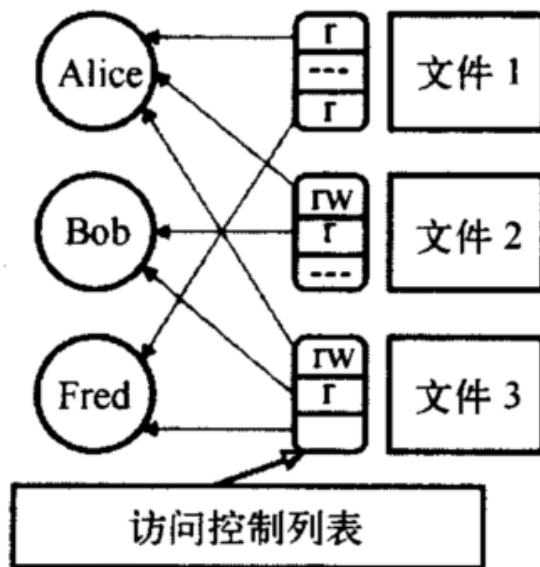
- C-list: 按行存储访问控制矩阵
- 示例: Alice 的权限以红色框显示

(OS, rx), (会计程序, rx), (会计数据, r),
(保险数据, rw), (薪水数据, rw).

	操作系统	会计程序	会计数据	保险数据	薪水数据
Bob	rx	rx	r	—	—
Alice	rx	rx	r	rw	rw
Sam	rwX	rwX	r	rw	rw
会计程序	rx	rx	rw	rw	r

访问控制列表VS能力表

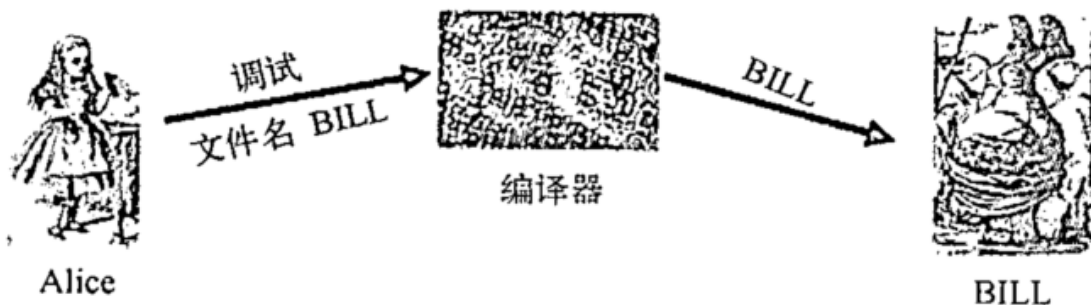
- 箭头方向：从资源到用户
- 需要独立的用户连接文件的方法



混乱代理 (confused deputy)

- 经典安全问题:
- 两个系统资源 (客体): 编译器, BILL文件。
- 主体: Alice

	编译器	BILL
Alice	x	—
编译器	rx	rw



编译器是为Alice工作的。
所以编译器是Alice的代理。
编译器被搞混乱了。
当它应该基于Alice的权利
操作时，它执行的是基于
自己权力的操作。

混乱代理

- ACL访问控制列表优点：
 - 适用于以数据为中心的权限管理,
 - 对单个资源修改权限容易
 - 实际应用更常见。

(Bob, —), (Alice, rw), (Sam, rw), (会计程序, rw)

- 能力表优点：
 - 易于权限委派,
 - 用户增加或删除方便,
 - 有助于避免混乱代理问题。
- 缺点：
 - 实现复杂,
 - 有时难以实际落地。

(OS, rx), (会计程序, rx), (会计数据, r),
(保险数据, rw), (薪水数据, rw).

多级安全模型

- 多级安全中，主体是用户，客体是要保护的数据（例如文档）。
- 密级应用于客体。
- 许可应用与主体。
- 美国国防部（DoD）采用 4 个密级：
 - 绝密（Top secret）**
 - 机密（Secret）**
 - 秘密（Confidential）**
 - 不保密（Unclassified）**

安全许可和分类

- 获得**机密级**安全许可，需要进行常规背景调查。
- 获得**绝密**安全许可，需要进行全面的背景调查和测谎仪测试。
- 实际密级分类问题
 - 正确的密级分类并不总是很明确。
 - 应用分类的粒度级别决定信息的密级。
 - 聚合——粒度的另一面

主体和客体

- 设O为**客体（资源，文档）**， S为**主体（用户）**
 - O具有**密级**。
 - S具有**许可**。
 - 安全**级别**用 $L(O)$ 和 $L(S)$ 表示。
- 对于国防部级别， 我们有
绝密>机密> 秘密>不保密

多级安全 (MLS)

- 当不同级别的主体/客体访问**同一系统时，需要多级安全 (MLS)**。
- 多级安全系统通过限制主体对客体进行访问时必须要有许可来加强访问控制。
- 军方和政府**对MLS（多级安全）**一直很感兴趣。
 - 对MLS进行了大量研究
 - MLS的优势和劣势已得到充分理解（几乎完全是理论性的）
 - MLS在军事领域之外还有许多潜在用途。

多级安全 (MLS)

- 政府/军事机密系统
- **商业示例：** 信息权限等级
 - 仅限高层管理人员、全体管理人员、公司所有员工或一般公众
- 网络防火墙
- 机密医疗信息、数据库等。
- 通常来说，MLS 并非一个真正的技术系统。
 - 更像是法律结构的一部分

MLS安全模型

- MLS安全模型解释了需要做**什么**。
- 模型**不会**告诉你**如何**实现
- 模型是描述性的，而非规范性的。
 - 也就是说，这是高层次的描述，而不是算法。
- MLS模型有很多种。
- 我们将讨论最简单的MLS模型
 - 其他模型更逼真。
 - 其他模型也更复杂、更难执行、更难验证等等。

Bell-LaPadula模型

- 目的：抓住MLS系统必须满足的安全性的最低要求。
- BLP处理保密事宜
 - 防止未经授权的读取
- O是客体（资源，文档）， S是主体（用户） 。
 - 客体O具有密级
 - 主体S具有许可
 - 安全级别用 $L(O)$ 和 $L(S)$ 表示。

Bell-LaPadula模型

- BLP由以下部分组成：

简单安全条件：当且仅当 $L(O) \leq L(S)$ 时，S可以读取O

***性质（星形性质）**：当且仅当 $L(S) \leq L(O)$ 时，
S可以写O

- **不上读，不下写**

简单安全条件：向下读
星特性：向上写

McLean 对BLP模型的评判

- McLean: BLP模型如此简单以至于很难想象它可以作为一个实际的安全模型。
- McLean定义了“Z系统”： 可以允许管理员临时地重新定义客体地密级，使其在不违反BLP规则的情况下被改写。
 - Z系统违反BLP精神。
 - 但系统没有明确禁止，所以这种行为可行。
- 引发了关于建模的本质（及其局限性）的根本性问题

B 和 LP 的回应

- BLP 增强了**稳定特性**

- **强稳定特性**: 安全标签永不改变
- **弱稳定特性**: 安全标签只有在不违反“既定安全策略”的情况下才能更改。

- 强稳定特性在现实世界中是不切实际的。

- 通常想要强制执行“最小权限原则”
- 分配当前工作所需的最低权限
- 然后根据需要（以及政策允许的情况）进行升级。
- 这就是所谓的**高级水印**原则

- 弱稳定特性允许享有**最小特权**（高级水印）。

BLP模型总结

- BLP很简单，可能太简单了。
- BLP是少数几种可以用来证明系统特性的安全模型之一。
- BLP启发了其他安全模型。
 - 其他大多数模型都力求更加逼真。
 - 其他安全模型则更为复杂。
 - 模型难以分析，难以实际应用

Biba模型

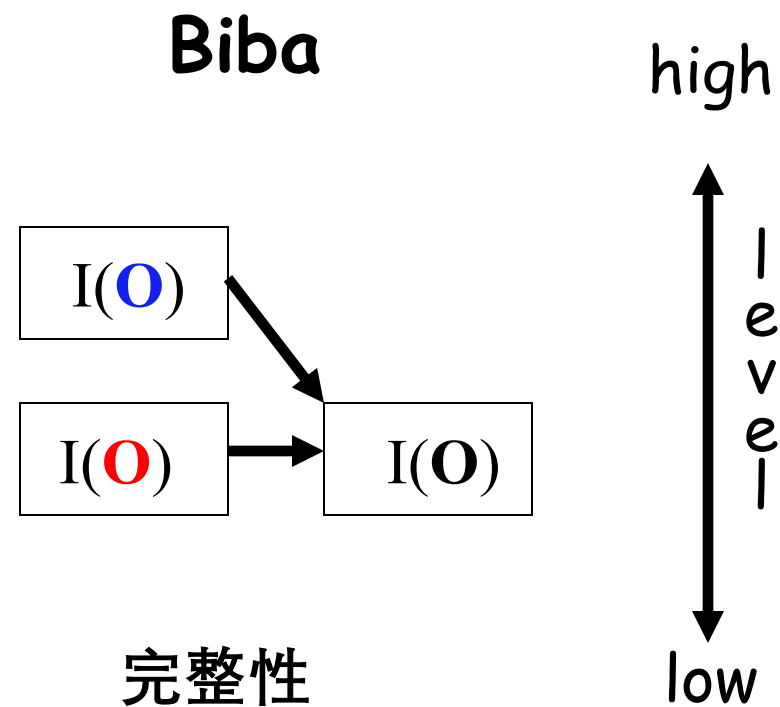
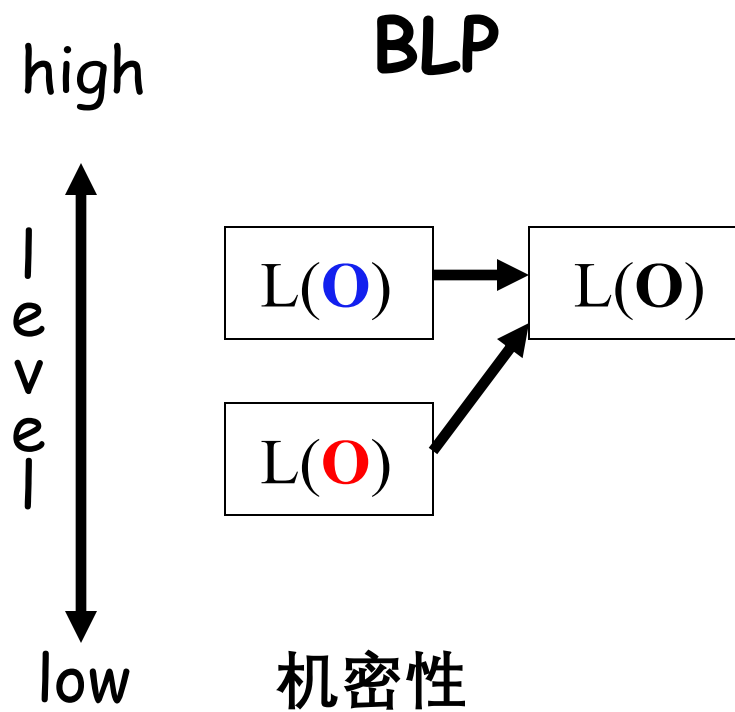
- BLP 用于机密性, Biba 用于完整性。
 - Biba模型用于防止未经授权的**写操作**。
- Biba模型是BLP模型的对偶模型（规则方向相反）
- 完整性模型
 - 假设你信任对象 **O** 的完整性，但不信任对象 **O**
 - 如果对象 **O** 包含了 **O**，那么你就**不能再信任** **O**
- 主体**O**的完整等级就是主体**O**对象中的最低完整性等级
- **完整性的低水位原则**

Biba模型

- 设 $I(O)$ 表示对象 O 的完整性级别， $I(S)$ 表示主体 S 的完整性级别
- 模型规则：
 - 写入权限规则：** 当且仅当 $I(O) \leq I(S)$ 时， S 可以写 O
(如果 S 写 O ，则 O 的完整性 $\leq S$ 的)
 - Biba的模型：** 当且仅当 $I(S) \leq I(O)$ 时， S 才能读取 O 。
(如果 S 读取 O ，则 S 的完整性 $\leq O$ 的)
- 低水印策略：如果主体 S 读客体 O ，那么 $I(S) = \min(I(S), I(O))$

下不读，上不写

BLP vs Biba



BLP vs Biba

- BLP: 不上读, 不下写
- Biba: 下不读, 上不写

场景	BLP	Biba
高级用户读低级数据	✓ 可以	✗ 不可以 (怕被污染)
高级用户写低级数据	✗ 不可以 (怕泄密)	✓ 可以
低级用户读高级数据	✗ 不可以	✓ 可以
低级用户写高级数据	✓ 可以	✗ 不可以

BLP vs Biba

- 典型应用场景

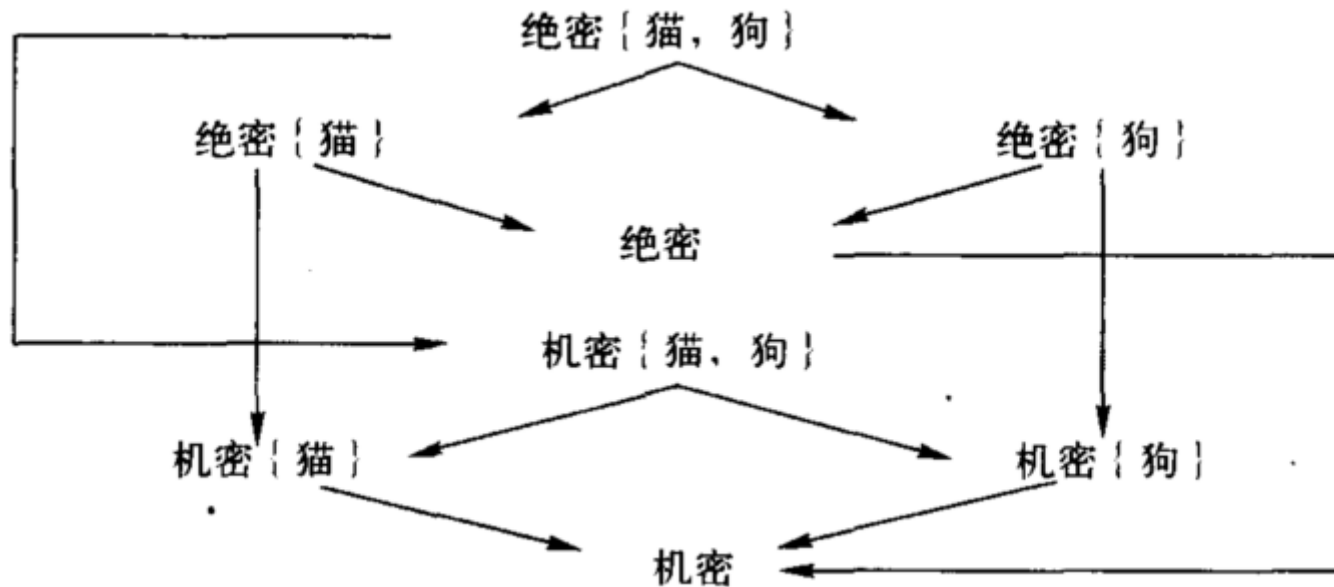
模型	适用场景
BLP	军事、政府机密系统（防泄密）
Biba	数据库、金融系统（防数据被篡改）

多边安全

- 多边安全采用分隔项来进一步限制**上下**双向访问控制。
- 简单的安全标签层级结构通常 **不是** 足够灵活。
- 用安全层和分割项来强制执行**各项限制**。
- 假设“**绝密**”分为“**绝密{猫}**”和“**绝密{狗}**”。
- 两者都属于**绝密级别**，但**绝密级别**内部的信息流动受到严格限制。
- 分割项：限制穿过安全层的信息流的作用。
- 目的：加强**需者方知原则**。（最小知情原则）

多边安全

- 多边安全模型:
- 箭头: $\geq$ 关系。



隐蔽通道

- MLS限制通信的合理通道。
- 隐蔽通道为信息流动提供了另一种途径。
 - 例如，不同层级共享的资源可以用来“传递”信息。
- 隐蔽通道：不是系统设计者所预期其存在的通信途径。

隐蔽通道示例

- Alice拥有**绝密级**安全许可， Bob拥有**机密级**安全许可。
- 假设所有用户共享同一个文件空间
- Alice 创建文件FileXYzW以向 Bob 发出“1”信号， 删除该文件以发出“0”信号。
- Bob每分钟列出一次文件
 - 如果文件FileXYzW不存在， Alice 发送 0。
 - 如果文件FileXYzW存在， Alice 发送 1
- 爱丽丝可以向鲍勃泄密

隐蔽通道示例

爱丽丝: 创建文件 删除文件 创建文件 删除文件

鲍勃: 检查文件 检查文件 检查文件 检查文件 检查文件

数据: 1 0 1 1 0

时间: 

隐蔽通道

- 还有其他可能的隐蔽通道吗？
 - 打印队列
 - ACK 消息
 - 网络流量等。
- 隐蔽通道何时存在？
 1. 发送方和接收方拥有共享资源
 2. 发送方能够改变接收方可以观察到的资源的某些属性。
 3. 发送方和接收方之间的“通信”可以同步。

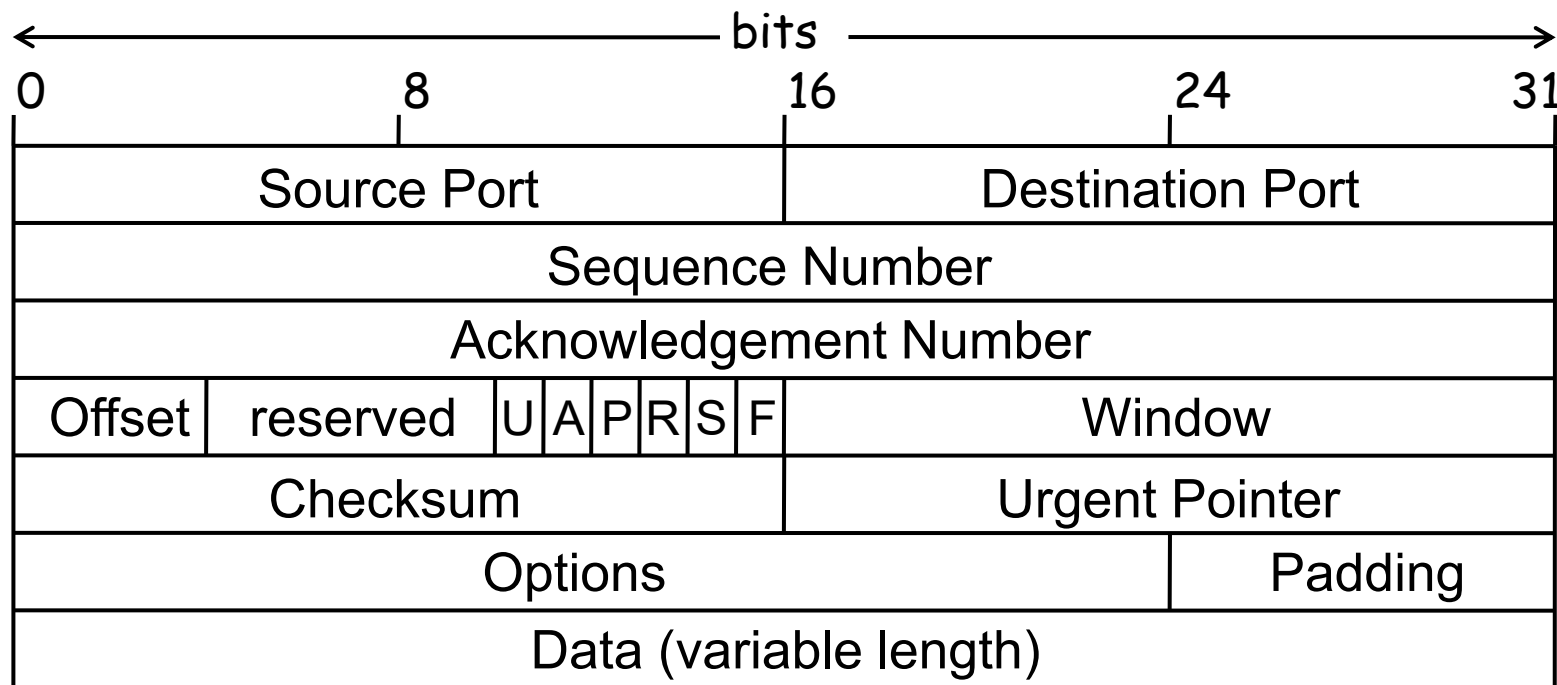
隐蔽通道

- 潜在的秘密渠道无处不在。
- 消除隐蔽渠道
 - “彻底”消除所有共享资源和所有沟通！
- 有用的信息系统
 - 美国国防部指导方针：将隐蔽信道容量降低至不超过 1 bit/s
 - 这意味着什么？ 国防部已经放弃消除秘密渠道。

隐蔽通道

- 考虑一个**100MB**的绝密文件
 - 明文存储在**绝密**位置
 - 密文 —— 使用 256 位密钥通过 AES 加密 —— 存放于**非密级**地点
- 假设我们将隐蔽通道容量降低到每秒 1 bit。
- 通过隐蔽通道泄露整份文件需要超过25年的时间。
- 但通过隐蔽通道泄露 256 位 AES 密钥只需要不到 5 分钟!

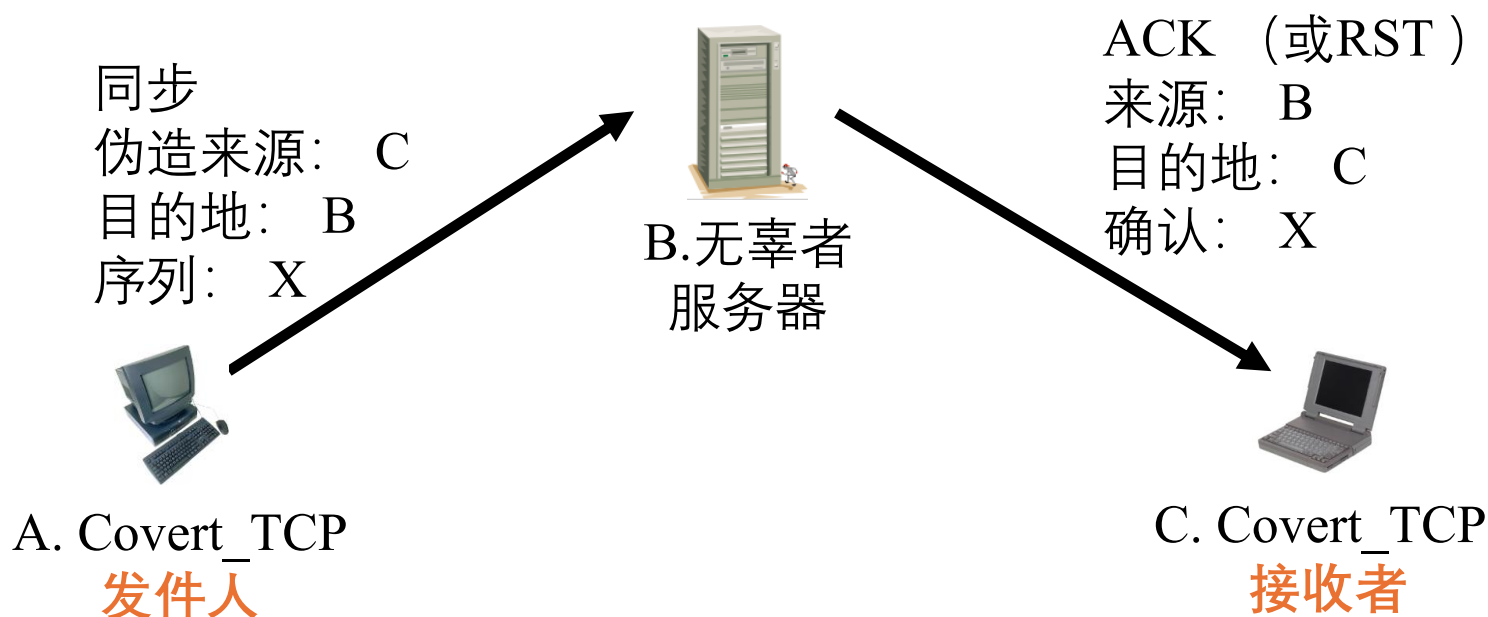
现实世界的隐蔽通道



- 隐藏 TCP 报头“保留”字段中的数据
- 或者使用covert_TCP工具来隐藏数据。
 - 序列号
 - ACK 号码

现实世界的隐蔽通道

- 将数据隐藏在 TCP 序列号中
- 工具：隐蔽式 TCP
- 序列号X包含秘密信息



推理控制

- 假设我们查询一个数据库
 - 问：圣何塞州立大学女性计算机科学教授的平均薪资是多少？
 - 答案： 95,000 美元
 - 问：圣何塞州立大学有多少位女性计算机科学教授？
 - 答案： 1
- 针对一般性问题的回复中泄露了具体信息！

推理控制与研究

- 例如， 医疗记录属于个人隐私， 但对研究很有价值。
- 如何既能提供研究信息又能保护隐私？
- 如何在不泄露具体信息的情况下允许访问此类数据？

朴素推理控制

- 从医疗记录中删除姓名?
- 尽管如此，从这类“匿名”数据中获取具体信息仍然可能很容易。
- 仅仅删除名字是不够的。
 - 如前例所示
- 还能做些什么?

朴素推理控制

- 查询集大小控制
 - 如果数据集太小，则不返回答案。
- N 个受访者， $k\%$ 优势规则
 - $k\%$ 或以上的数据，则不发布该统计数据。
 - 例如： 比尔·盖茨所在社区的平均工资
 - 美国人口普查局采用的这种方法
- 随机化
 - 向数据中添加少量随机噪声
- 其他许多方法——但没有一种令人满意。

Netflix 示例

- Netflix 奖金——首位将推荐系统性能提升 10% 或以上的开发者将获得 100 万美元奖励。
- Netflix 为比赛创建了数据集
 - 真实用户的电影偏好
 - 已移除用户名，并添加了一些“噪音”。
- 推理控制不足
 - 研究人员能够将IMDb评论与Netflix数据集中的评论进行关联。

总比没有强？

- 稳健的推理控制可能是不可能的
- 弱推理控制总比没有好吗？
 - **是的**：减少了信息泄露的数量。
- 薄弱的隐蔽通道保护总比没有好吗？
 - **是的**：减少了信息泄露的数量。
- 弱加密比没有加密更好吗？
 - **可能不是**：加密表示重要数据
 - 过滤加密数据可能更容易。

图灵测试

- 由艾伦·图灵于1950年提出
- 由一个人提问，让另一个人和一台电脑进行回答，但相互之间都不能见面。
- 如果提问者无法区分人和计算机的回答的话，则计算机通过。
- 这是人工智能领域的**黄金标准**。

CAPTCHA

Completely Automated Public Turing test to tell
Computers and Humans Apart

- CAPTCHA: 全自动区分计算机和人类的图灵测试
- 完全**自动化**——测试由计算机生成和评分。
- **公开**——程序和数据是公开的
- **图灵**测试可以告诉我们..... ——
人类可以通过测试，但机器不能。
 - 也称为**HIP** == **H**uman **I**nteractive **P**roof
- 有点像逆向图灵测试（某种程度上.....）

CAPTCHA悖论

- “.....CAPTCHA是一个能够生成并批改自己都无法通过的测试的程序.....”
- 悖论——
计算机创建并评分了它自己都无法通过的测试!
- CAPTCHA的用途?
 - 只有人类才能访问 (机器人/计算机不能访问)
- 所以, CAPTCHA是用于**访问控制的**。

CAPTCHA

- 最初的动机是什么?
 - 自动机器人操纵选票，操纵最佳计算机科学研究生院的投票。
 - 麻省理工学院对阵卡内基梅隆大学。

- 免费电子邮件服务

- 使用验证码以确保只有真人才能注册账号

- 不希望被搜索引擎自动索引的网站

- 验证码将强制人工干预

在线投票系统（防刷票）
注册系统（防垃圾账号）
免费邮箱服务（防批量注册）
网站访问控制（防爬虫）

CAPTCHA

- 对大多数人来说很容易通过
- 机器难以或不可能通过
 - 即使可以使用验证码软件
- 在攻击者看来，唯一未知数就是一个随机数。
 - 与柯克霍夫原理
- 最好设置不同的验证码，以防有人无法通过一种验证码。
 - 例如，盲人无法通过视觉验证码。

CAPTCHA

- 测试：从下列句子中找出两个单词。



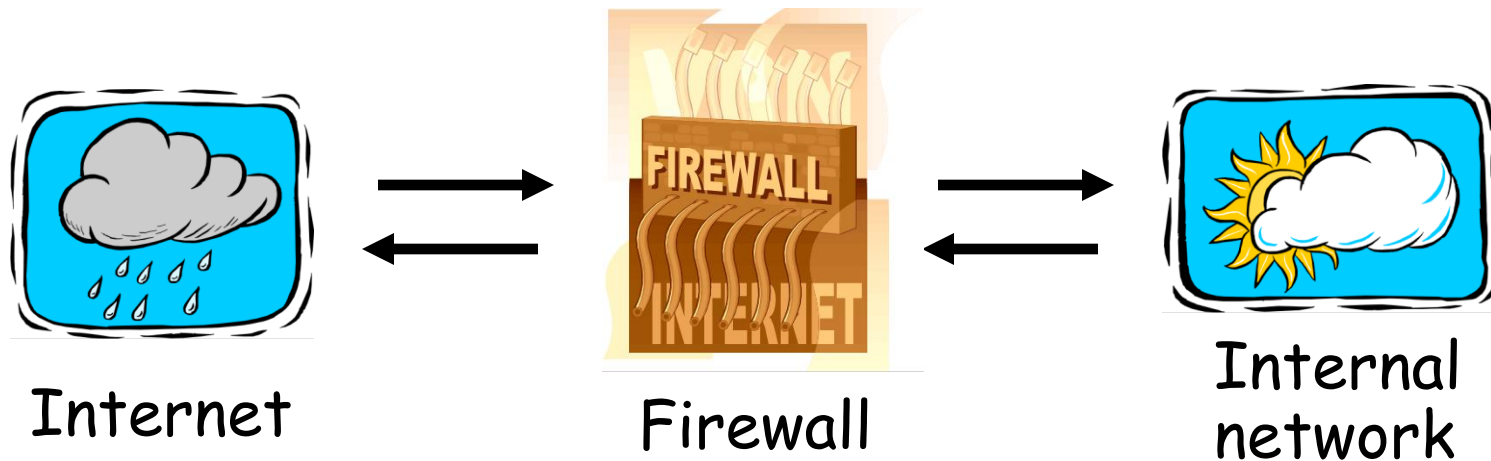
- 对大多数人来说很容易
- 计算机
 - OCR——光学字符识别

验证码和人工智能

- OCR是一个具有挑战性的人工智能问题
 - 最难的部分是**分割问题**
 - 人类擅长解决这个问题
- 失真的声音适合做验证码。
 - 人类也很擅长解决这个问题。
- 破解验证码的黑客已经解决了一个棘手的AI难题（例如OCR）。
 - 所以，黑客的努力得到了有效利用！
- 还有其它方法可以绕过验证码吗？

防火墙

- 防火墙决定允许哪些内容进入内部网络以及允许哪些内容离开内部网络。
- 网络访问控制



防火墙

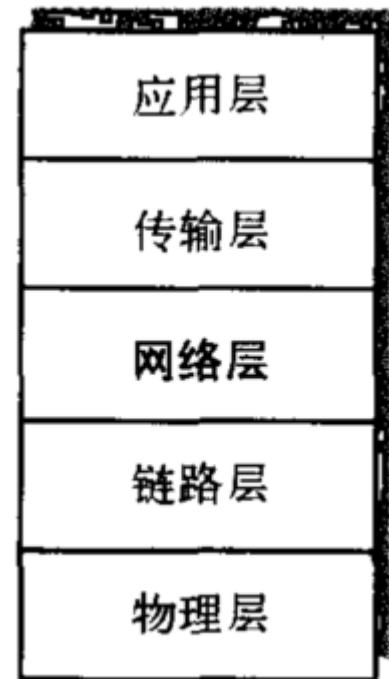
- 防火墙就像**秘书**
- 与高管会面
 - 先联系秘书
 - 秘书决定会议是否重要
 - 所以，秘书过滤掉了许多请求。
- 你想见计算机科学系主任吗？
 - 秘书进行了一些筛选
- 你想见美国总统吗？
 - 秘书做了很多筛选工作。

防火墙术语

- 没有标准的防火墙术语
- 防火墙的类型
 - **数据包过滤器** ——在网络层工作
 - **状态数据包过滤器** ——在传输层工作
 - **应用程序代理** ——在应用层工作
- 还有很多其他常用术语
 - 例如, “深度包检测”

数据包过滤器

- 包过滤器防火墙是用来检测**网络层**上的数据包。
- 仅能通过基于网络层的数据信息来过滤包。
 - 源IP地址
 - 目的IP地址
 - 源端口
 - 目的端口
 - TCP标志位 (SYN, ACK, RST)
- 对入包和出包有不同的过滤规则。



数据包过滤器

- 优势
 - 效率高：过滤操作只到**网络层**，只检测头信息。
- 缺点
 - 没有状态概念，每个包都视为独立
 - 无法查看 TCP 连接
 - 对应用程序数据不过滤（应用数据常隐藏病毒）

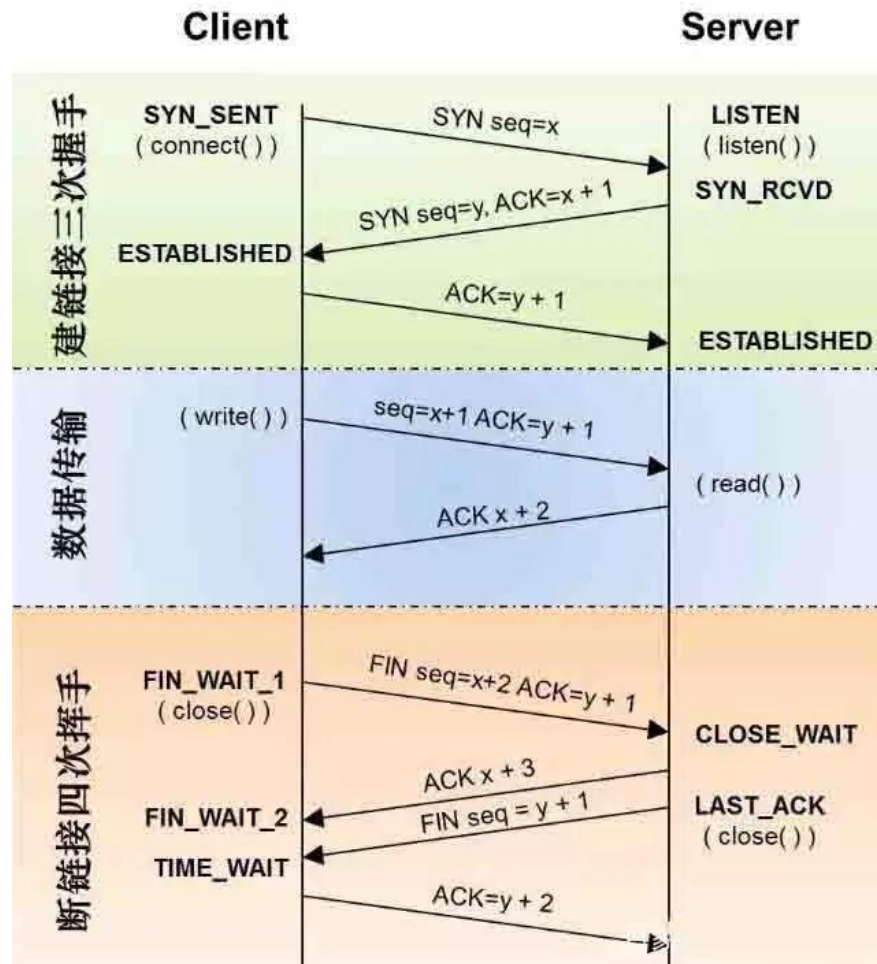
数据包过滤器

- 包过滤器采用访问控制表（ACL）来配置。
 - 与前面讲的ACL所表达的内容不同
 - 内部 → 外部（访问 Web，端口 80）
 - 外部 → 内部（响应包，ACK）
- 只允许明确允许的，其余全部拒绝

操作	源 IP	目的 IP	源端口	目的端口	协议	标志位
允许	内部	外部	任意	80	HTTP	任意
允许	外部	内部	80	> 1023	HTTP	ACK
拒绝	所有	所有	所有	所有	所有	所有

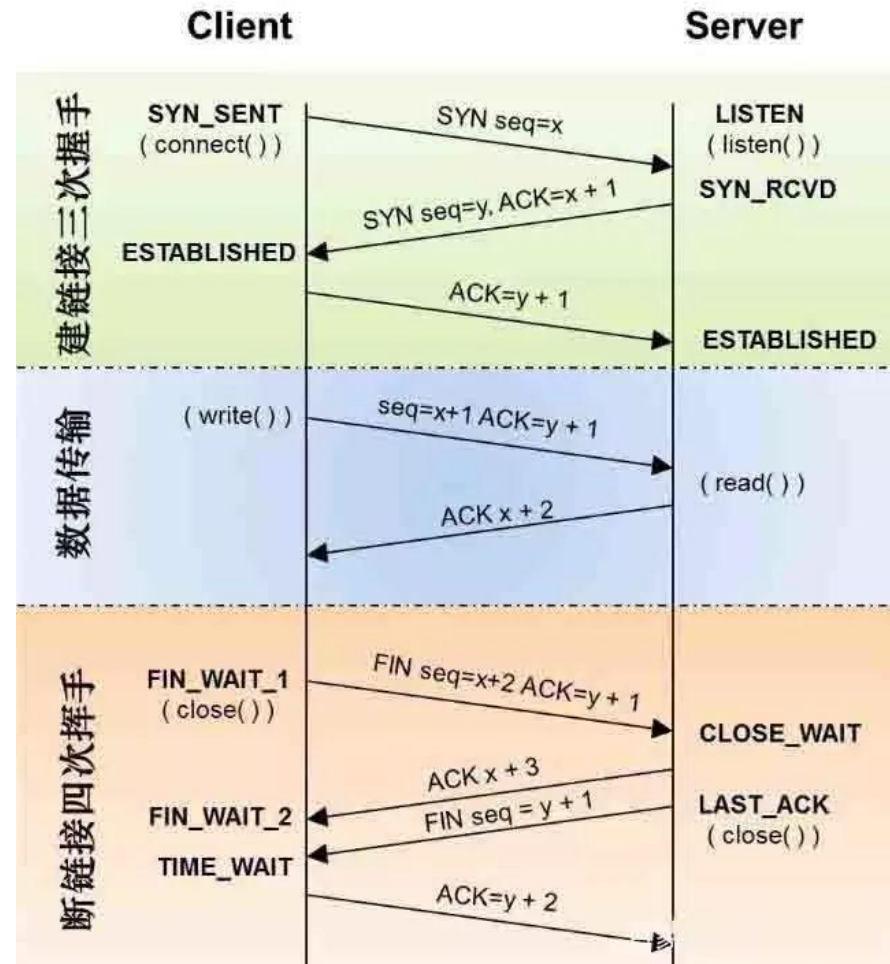
数据包过滤器

- 攻击者通过防火墙扫描开放端口。
 - 端口扫描通常是网络攻击的**第一步**
- 攻击者发送数据包时**未**事先进行三次握手，且 ACK 位已设置。
 - 包过滤器会认为是正常连接的包而直接放行。

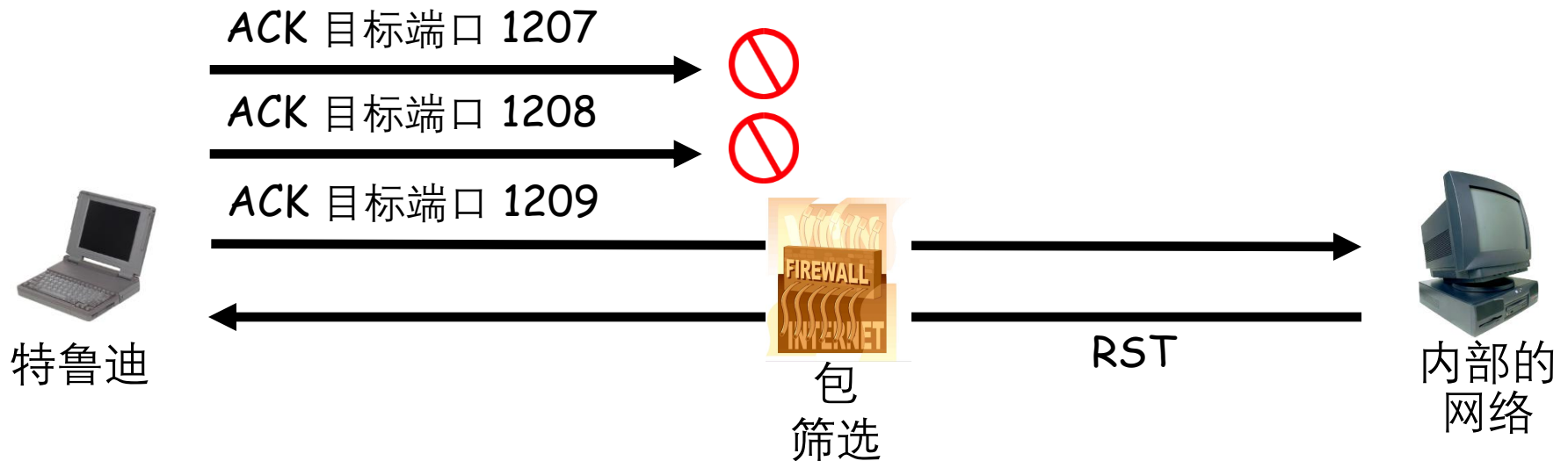


数据包过滤器

- 违反 TCP/IP 协议
- ACK 数据包通过数据包过滤防火墙
- 接收方发送异常ACK响应包, 发送RST数据包给包过滤器, 断开连接。
- 攻击者通过是否收到RST来判断端口状态。



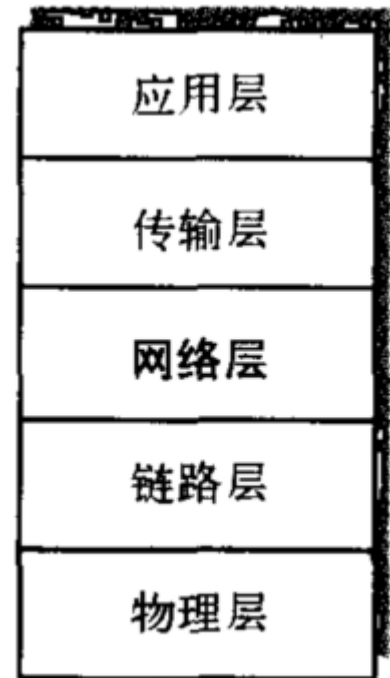
TCP ACK扫描



- 攻击者知道防火墙已打开 1209 端口。
- 有**状态数据包过滤器**可以防止这种情况发生。
 - 由于扫描并非已建立连接的一部分，因此扫描不属于任何已建立的连接。

有状态数据包过滤器

- 向数据包过滤器添加**状态**
- 在**传输层**运行
- 记住TCP 连接、标志位等信息。
- 甚至可以记住UDP数据包（例如， DNS请求）



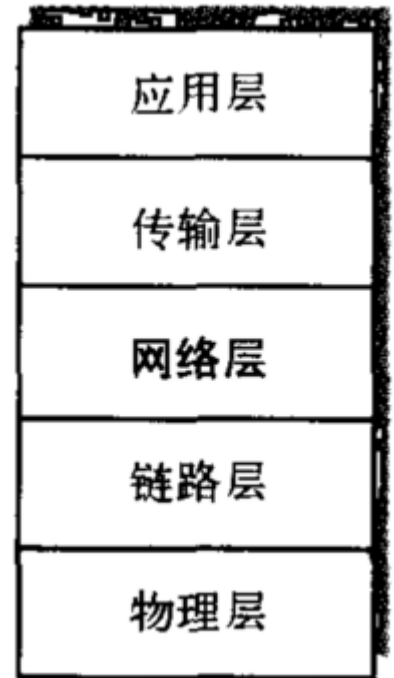
有状态数据包过滤器

- 优势

- 它能做到数据包过滤器能做的一切，外加.....
- 跟踪正在进行的连接（例如，防止TCP ACK扫描）

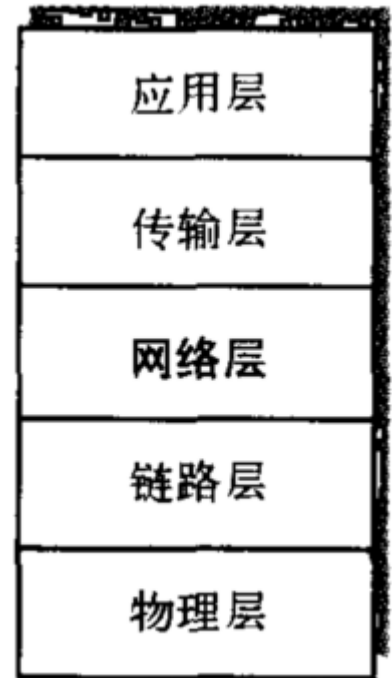
- 缺点

- 无法查看应用程序数据
- 比数据包过滤慢



应用代理

- 代理是作为用户的代表，按照用户定义的规则行事。
- 应用代理防火墙处理应用层上的所有包。
- 按照定义行为模式核实包的合法性。
- 优点：
 - 连接和应用程序数据的完整视图。
 - 应用层过滤不良数据，传输层过滤坏包。
- 缺点：
 - 速度



应用代理

- 特性：发送到内部网络之前，应用代理创建一个*新的数据包*。
- 攻击者必须与**代理服务器通信**，并说服其转发消息。
- 代理拥有完整的连接视图
- 可以阻止某些扫描，但有状态数据包过滤器无法做到——
下一页

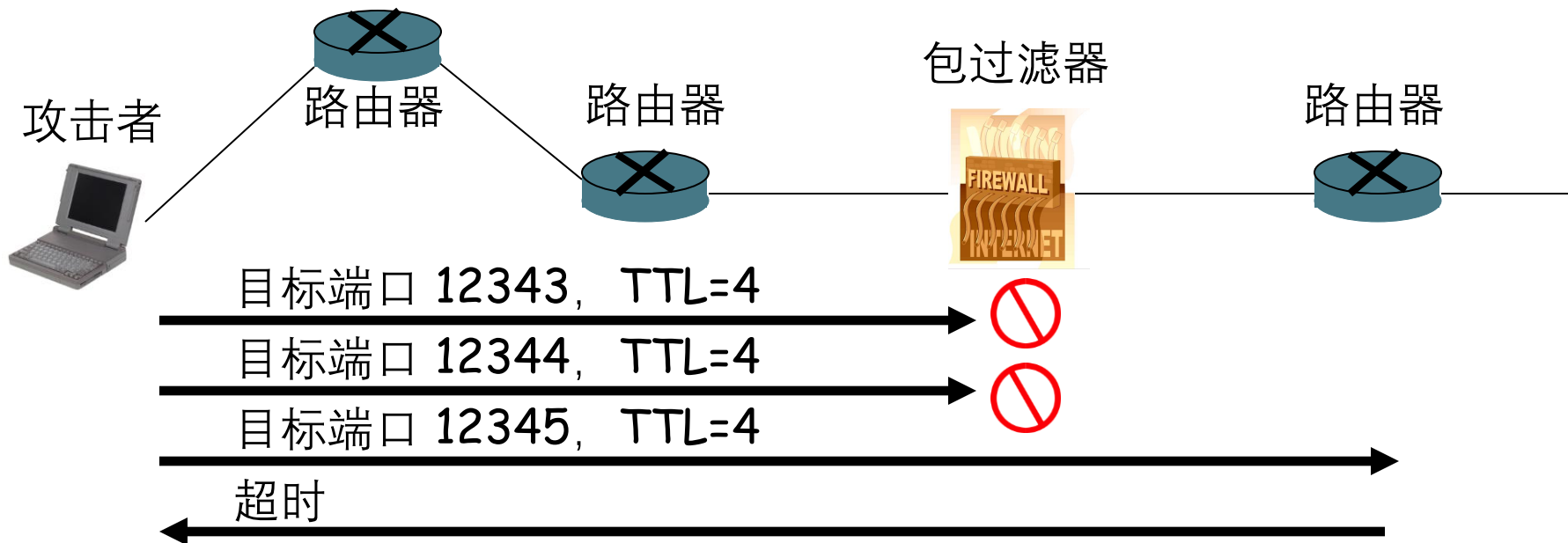
应用代理

- 发送到内部网络之前，会创建一个*新的数据包*。
- 攻击者必须与**代理服务器通信**，并说服其转发消息。
- 代理拥有完整的连接视图
- 可以阻止某些扫描，但有状态数据包过滤器无法做到这一点。

Firewalk

- 用于扫描防火墙开放端口的工具
- 攻击者知道防火墙的 IP 地址和防火墙内某个系统的 IP 地址。
 - 将 TTL 值设置为比防火墙跳数多 1，并将目标端口设置为 N
- 如果防火墙允许端口 N 上的数据通过防火墙，则会收到**超时**错误消息。
 - 否则，不予回复

Firewalk 和代理防火墙



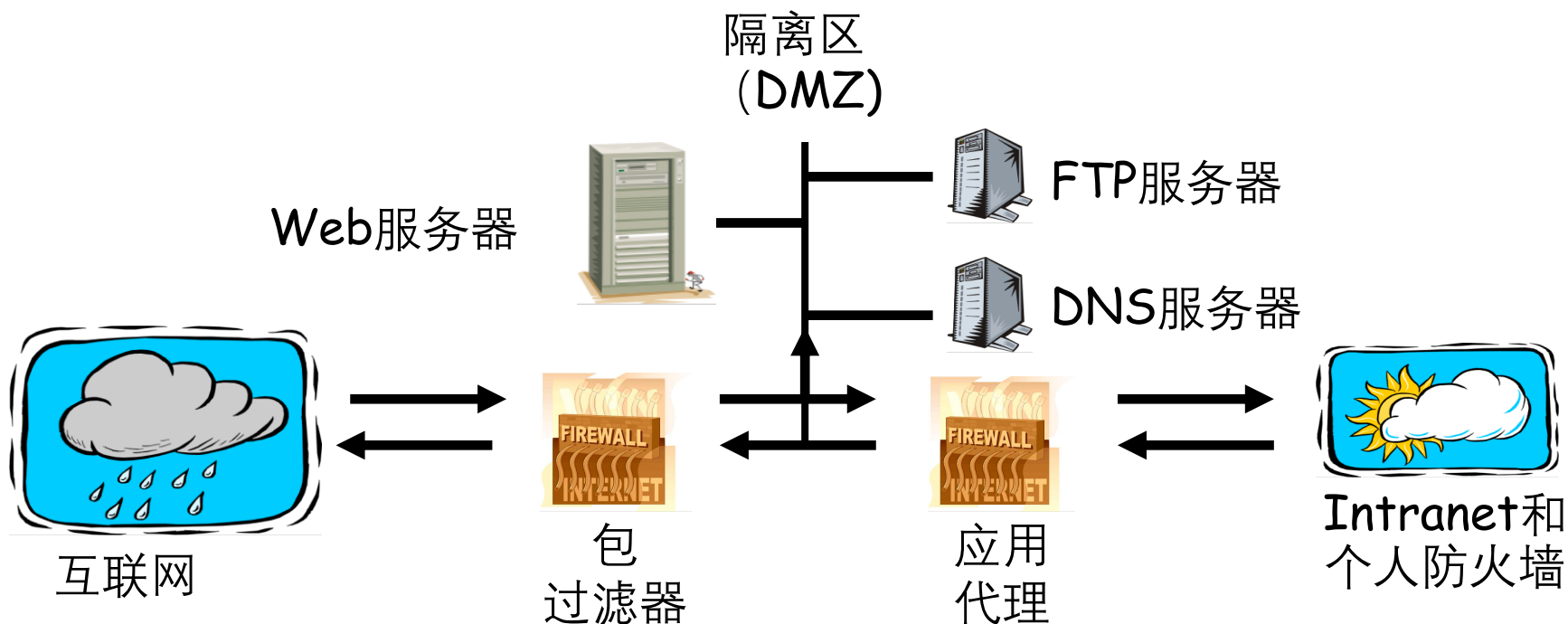
- 这将 **无法** 通过应用程序代理运行（为什么？）
- 代理服务器创建一个新数据包，并销毁旧的 TTL 数据包。

个人防火墙

- 个人防火墙用来保护单个主机或者小型网络。
- 包过滤器，状态包过滤器或者应用代理均可以使用。
- 个人防火墙通常配置简单。

深度防御

- 典型的网络安全架构



深度防御

- **包过滤器**用来阻止对DMZ中系统的低层攻击。这些系统接受大部分的外部流量，处于效率考虑，将简单的包过滤器用于此。
- **应用代理**防火墙处于内网和DMZ中间。为内网提供尽可能强大的防火墙保护。
- 作为保护的最后一层，**个人防火墙**可能在整个网络中的个人主机上进行配置。

入侵检测

- 想把坏人挡在外面
- **入侵防御**是计算机安全领域的传统重点。
 - 身份验证是为了防止入侵。
 - 防火墙是一种入侵防御措施
 - 旨在阻止入侵的病毒防御
 - 就像锁车门一样

入侵检测

- 尽管采取了入侵防御措施，坏人有时还是会入侵。
- 入侵检测系统（**IDS**）
 - 检测正在进行中的攻击（或攻击结束后不久）
 - 留意异常或可疑活动
- IDS是从日志文件分析发展而来的。
- IDS目前是一个**热门的**研究课题。
- 检测到入侵时应如何应对？
 - 我们这里不讨论这个话题.....

入侵检测

- 谁可能是入侵者?
 - 可能是**外部人员**突破了防火墙。
 - 可能是邪恶的**内部人员**
- 入侵者会做什么?
 - 发动众所周知的攻击
 - 针对已知攻击发起变种攻击
 - 发起新的/鲜为人知的攻击
 - “借用”系统资源
 - 利用被入侵的系统攻击他人，等等。

入侵检测

- 入侵检测**方法**
 - 基于签名的入侵检测系统
 - 基于异常的入侵检测系统
- 入侵检测**架构**
 - 基于主机的入侵检测系统
 - 基于网络的入侵检测系统
- 任何入侵检测系统都可以按上述方式分类。
 - 尽管营销宣传与此相反!

基于主机的入侵检测系统

- 监控主机上的活动
 - 已知攻击
 - 可疑行为
- 旨在检测诸如此类的攻击
 - 缓冲区溢出
 - 权限升级,
- 对网络活动几乎没有或完全没有了解

基于网络的入侵检测系统

- 监控网络活动.....
 - 已知攻击
 - 可疑的网络活动
- 旨在检测诸如此类的攻击
 - 拒绝服务
 - 网络探测
 - 格式错误的数据包等。
- 与防火墙存在部分重叠
- 几乎没有或完全没有针对主机基地的攻击
- 可以同时具备主机和网络入侵检测系统。

基于签名入侵检测示例

- 登录失败可能表明遭受了密码破解攻击
 - M秒内N 次登录尝试失败”规则作为**签名**
- 如果在M秒内尝试登录失败N次或更多次，入侵检测系统 (IDS) 将发出攻击警告。
- 请注意，此类警告具有针对性。
 - 管理员知道怀疑的是哪种攻击。
 - 易于验证的攻击（或误报）

基于签名入侵检测示例

- 假设入侵检测系统 (IDS) 在 M 秒内发生 N 次或更多次登录失败时发出警告。
 - 设置 N 和 M 值，以避免误报。
 - 可以根据“正常”行为做到这一点
- 但是，如果特鲁迪知道签名，她可以尝试每 M 秒内 $N-1$ 次登录.....
- 特征识别技术会减缓攻击者的行动，但可能无法阻止她。

基于签名入侵检测示例

- 许多技术被用于增强签名检测的鲁棒性。
- 目标是检测“几乎”相同的特征。
- 例如， 如果“大约” M 秒内有“大约” N 次登录尝试
 - 警告： 可能存在密码破解尝试
 - “about”的合理值是多少？
 - 可以使用统计分析、启发式方法等。
 - 切勿过度提高误报率

基于签名入侵检测示例

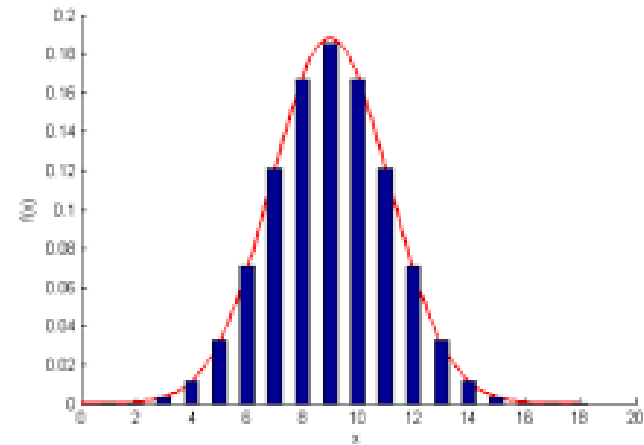
- 基于签名检测的优势
 - 简单的
 - 检测已知攻击
 - 知道检测到攻击时属于哪种攻击。
 - 高效（如果签名数量合理）
- 基于签名检测的缺点
 - 签名文件必须保持最新状态。
 - 签名数量可能会很大
 - 只能检测已知攻击
 - 已知攻击的变种可能无法被检测到。

基于异常入侵检测

- 异常检测系统会寻找异常或不寻常的行为。
- 至少存在两个挑战
 - 这个系统的正常情况是什么?
 - 与正常状态“相差”多远才算异常?
- 这里无法回避统计数据!
 - **均值**定义了正常
 - **方差**表示从正常值到异常值的距离

基于异常入侵检测

- 如何衡量正常水平？
 - 必须在“代表性”行为期间进行测量
 - 攻击期间不得进行测量.....
 - 否则，攻击就会显得很正常！
 - 正态分布是统计**均值**
 - 还必须计算**方差**，才能对异常情况有合理的了解。



基于异常入侵检测

- 异常是相对于某种“正常”而言的。
 - 异常情况表明可能发生攻击
- 统计判别技术包括
 - 贝叶斯统计
 - 线性判别分析 (LDA)
 - 二次判别分析 (QDA)
 - 神经网络、隐马尔可夫模型 (HMM) 等。
- 还使用了精巧的建模技术。
 - 人工智能
 - 人工免疫系统原理
 - 还有很多很多其他

异常检测 (1)

- 我们监控这三个命令的使用情况
打开、阅读、关闭
- 如果异常配对与正常配对的比例“过高”，则应发出可能发生攻击的警告。
- 可以通过以下方式改进这种方法
 - 同时使用每对的预期频率
 - 使用两个以上的连续命令
 - 在模型中添加更多命令/行为
 - 更复杂的统计判别

异常检测 (2)

- 过去, Alice 访问文件 F_n 的频率为 H_n

H_0	H_1	H_2	H_3
.10	.40	.40	.10

- 最近, "**Alice**" 访问文件 F_n 的频率为 A_n

A_0	A_1	A_2	A_3
.10	.40	.30	.20

- 这是 **Alice** 的正常使用吗?
- 计算 $S = (H_0 - A_0)^2 + (H_1 - A_1)^2 + \dots + (H_3 - A_3)^2 = .02$
 - 我们考虑 $S < 0.1$ 是正常的, 所以这是正常的。
- 怎么解释随时间变化的使用情况?

异常检测 (2)

- 为了使正常也适用与新的使用状态, 我们平均更新频率: $H_n = 0.2A_n + 0.8H_n$
- 这里, 新的 H_n 更新...
- $H_2 = .2 * .3 + .8 * .4 = .38$ and $H_3 = .2 * .2 + .8 * .1 = .12$
- 所以更新后的值为

H_0	H_1	H_2	H_3
.10	.40	.38	.12

异常检测 (2)

- 长期更新的平均值为

H_0	H_1	H_2	H_3
.10	.40	.38	.12

- 假设新观察到的数据为...

A_0	A_1	A_2	A_3
.10	.30	.30	.30

- 这个记录正常吗?
 - 计算 $S = (H_0 - A_0)^2 + \dots + (H_3 - A_3)^2 = .0488$
 - 如果 $S = .0488 < 0.1$ 我们认为这正常。
 - 那么再重新计算长期更新平均值:
- $$H_n = 0.2A_n + 0.8H_n$$

异常检测 (2)

• 初始平均状态为:

H_0	H_1	H_2	H_3
.10	.40	.40	.10

□ 两次迭代更新后:

H_0	H_1	H_2	H_3
.10	.38	.364	.156

- 统计数据会随着用户行为逐渐变化并进行适配
- 可以减少 SA (安全管理员) 的误报
- 这也为攻击提供了一种途径...
 - 假设攻击者总是想访问文件 F_3
 - 他能够让IDS认为这是Alice正常操作?

异常检测 (2)

- 为了使这种方法更加稳健，必须考虑方差。
- 还可以将N 个统计数据 S_i 组合起来，例如，

$$T = (S_1 + S_2 + S_3 + \dots + S_N) / N$$

为了更全面地了解“正常”的含义

- 一种名为**NIDES的入侵检测系统**也投入应用。
- NIDES 结合了异常检测和签名检测入侵检测系统

异常检测问题

- 系统不断发展演进，入侵检测系统也必须如此。
 - 静态系统会给管理员带来巨大的负担。
 - 但不断演进的入侵检测系统使得攻击者有可能（缓慢地）让入侵检测系统相信攻击是正常的。
 - 攻击者可能仅仅通过“放慢速度”就能获胜。
- “异常”究竟意味着什么？
 - 表明可能发生攻击
 - 可能不会提供关于“攻击”的具体信息。
 - 如何应对这种模糊不清的信息？
 - 相比之下，签名检测则非常具体。

基于异常的检测

- 优势?
 - 检测到未知攻击的概率
- 缺点?
 - 不能单独使用异常检测.....
 - 必须与签名检测一起使用
 - 可靠性尚不明确
 - 可能遭受攻击
 - 异常检测表明存在“不寻常的情况”，但缺乏关于可能攻击的具体信息。

Thank you.